

PRODUCT REQUIREMENTS DOCUMENT (PRD)

System Forensic Scanner (SFS)

Version: 1.0

Status: Approved

Target Release: v1

Technology Stack:

- Golang
 - Postgree
 - YARA
 - Katana
 - Nuclei
 - Httpx
 - HTML Report Engine
 - PDF Report Engine
-

1. PRODUCT OVERVIEW

System Forensic Scanner (SFS) adalah platform digital forensic dan incident response berbasis Golang yang dirancang untuk melakukan investigasi terhadap aplikasi web yang diduga telah mengalami kompromi keamanan.

Sistem bekerja secara read-only dan tidak melakukan modifikasi terhadap target.

Target utama versi pertama:

- Open Journal Systems (OJS)
- Wordpress
- Laravel
- Moodle
- Generic PHP Application

Sistem harus mampu:

- Mendeteksi file yang dimodifikasi
- Mendeteksi file tambahan yang tidak resmi
- Mendeteksi malware/webshell
- Mendeteksi IOC (Indicators of Compromise)
- Membandingkan source code dengan baseline bersih
- Melakukan forensic database dari SQL Dump
- Melakukan attack surface discovery

- Melakukan vulnerability assessment
 - Menghasilkan timeline insiden
 - Menghasilkan laporan investigasi
-

2. PRODUCT GOALS

Goal utama:

1. Mengidentifikasi kompromi aplikasi
 2. Mengidentifikasi persistence mechanism
 3. Mengidentifikasi malware/webshell
 4. Mengidentifikasi attack path
 5. Mengidentifikasi root cause
 6. Menghasilkan evidence report
-

3. NON-GOALS

Versi pertama tidak akan:

- Menghapus malware
 - Memperbaiki file
 - Memindahkan file
 - Menonaktifkan plugin
 - Melakukan patch otomatis
 - Menjalankan exploit
-

4. PLATFORM SUPPORT

Supported OS:

- Windows 10+
- Windows Server
- Ubuntu 20+
- Ubuntu 22+
- Debian
- CentOS

Architecture:

- AMD64
 - ARM64
-

5. USER ROLES

Administrator

Hak akses:

- Membuat project
- Upload baseline
- Menjalankan scan
- Melihat report
- Export report

Single admin account untuk v1.

6. SYSTEM ARCHITECTURE

Layer:

Presentation Layer

↓

Application Layer

↓

Scan Engine Layer

↓

Evidence Layer

↓

Storage Layer

7. MODULE ARCHITECTURE

modules/

- baseline
- hash
- diff
- yara
- ioc
- katana
- nuclei
- httpx
- database
- timeline
- report
- risk
- plugins

8. PROJECT STRUCTURE

cmd/

internal/

api/

web/

plugins/

reports/

signatures/

storage/

temp/

logs/

9. PROJECT MANAGEMENT

Project Entity:

- Project Name
- Target Type
- Target Path
- Baseline Path
- Creation Date

Status:

- Pending
 - Running
 - Completed
 - Failed
-

10. BASELINE ENGINE

Fungsi:

Membandingkan target dengan source bersih.

Input:

Target Folder
Baseline Folder

Output:

- Added File
- Modified File
- Deleted File

Hash:

SHA256

11. HASH ENGINE

Hash seluruh file.

Output:

```
{  
  "path": "",  
  "hash": "",  
  "size": "",  
  "mtime": ""  
}
```

Digunakan untuk:

- Integrity Verification
 - Timeline
 - Diff
-

12. DIFF ENGINE

Library:

go-difflib

Output:

- Before
- After
- Unified Diff

Kategori:

LOW

MEDIUM

HIGH

CRITICAL

13. YARA ENGINE

Library:

go-yara/v4

Sumber Rules:

- Local Cache
- Neo23x0 Rules
- YARA-Rules Project

Fungsi:

Deteksi:

- Webshell
- Backdoor
- Trojan
- Downloader
- Obfuscation

Output:

Rule Name

Severity

Matched Strings

File

14. IOC ENGINE

Deteksi pola:

```
eval(  
base64_decode(  
shell_exec(  
system(  
exec(  
passthru(  
assert(  

```

create_function(
gzinflate(
str_rot13(

Output:

IOC Score

15. FILE AUDIT ENGINE

Mode:

CORE
FULL
CRITICAL

CORE

classes/
controllers/
plugins/
api/

FULL

Seluruh Folder

CRITICAL

config
security
plugins
upload
public

16. PLUGIN AUDIT ENGINE

Target:

OJS
Wordpress
Moodle

Deteksi:

- Unknown Plugin

- Suspicious Plugin
- Modified Plugin

Risk Level:

LOW

MEDIUM

HIGH

CRITICAL

17. DATABASE FORENSIC ENGINE

Input:

.sql

.sql.gz

.zip

Supported:

MySQL Dump

MariaDB Dump

Analysis:

Users

Roles

Sessions

Submissions

Login Records

Deteksi:

- User Baru
 - Privilege Escalation
 - Suspicious Submission
-

18. TIMELINE ENGINE

Data Sources:

Filesystem

Apache Logs

Application Logs

Database Dump

Output:

Timeline Event

Contoh:

01:12 plugin upload

01:13 shell.php dibuat

01:15 artikel palsu dibuat

01:17 login admin

19. KATANA ENGINE

Purpose:

Attack Surface Discovery

Mode:

Anonymous Crawl

Authenticated Crawl

Cookie Session Crawl

Input:

Target URL

Cookie

Depth

Output:

Endpoints

Parameters

Forms

Upload Endpoints

Admin Endpoints

20. HTTPX ENGINE

Purpose:

Technology Detection

Output:

- Server
 - Framework
 - Headers
 - TLS
 - Cloudflare
-

21. NUCLEI ENGINE

Execution Mode:

External Binary

Output:

- CVE
- Misconfiguration
- Exposed Files
- Weak Configuration

Severity:

Info

Low

Medium

High

Critical

22. RISK ENGINE

Scoring:

Webshell = 100

YARA Hit = 90

Modified Core File = 80

Unknown Plugin = 70

Critical CVE = 60

IOC Match = 40

Missing Security Header = 10

Final Verdict:

0-25 SAFE

26-50 SUSPICIOUS

51-75 COMPROMISED

76-100 CRITICALLY COMPROMISED

23. EVIDENCE STORAGE

Store:

Original Hash

Modified Hash

File Diff

YARA Result

IOC Result

Timeline

Nuclei Result

Katana Result

24. REPORT ENGINE

Formats:

JSON

HTML

25. JSON REPORT

Sections:

Summary

Risk Score

Evidence

Timeline

Findings

26. HTML REPORT

Sections:

Executive Summary

Attack Surface

Modified Files

Malware Findings

Timeline

Risk Analysis

Recommendations

27. PDF REPORT

Sections:

Management Summary

Technical Findings

Evidence

28. DASHBOARD

Features:

Projects

Scans

Reports

Evidence

Settings

29. SCAN WORKFLOW

Create Project



Upload Baseline



Select Target



Hash Scan



Diff Scan



YARA Scan



IOC Scan



Database Scan



Katana Scan



Httpx Scan



Nuclei Scan



Timeline Build



Risk Score



Report Generation

30. SECURITY REQUIREMENTS

Read Only Mode

No File Modification

No Shell Execution on Target

No Auto Remediation

No Exploit Execution

31. PERFORMANCE TARGET

100.000 Files

Scan Time:

< 15 Minutes

Memory:

< 2 GB

Concurrent Workers:

Configurable

32. DATABASE

SQLite

Tables:

users

projects

scans

findings

timeline

evidence

reports

risk_scores

33. FUTURE ROADMAP

V2

Live Database Connection

Multi User

API Authentication

Cluster Scan

Distributed Scan

V3

Automatic Baseline Download

Cloud Scan

Agent Mode

Continuous Monitoring

Real Time Alerting

SIEM Integration

SOC Integration

EDR Integration

ACCEPTANCE CRITERIA

Scanner mampu:

✓ Membandingkan source dengan baseline

✓ Mendeteksi file tambahan

- ✓ Mendeteksi file dimodifikasi
- ✓ Menjalankan YARA
- ✓ Menjalankan IOC Scan
- ✓ Parsing SQL Dump
- ✓ Menjalankan Katana
- ✓ Menjalankan Httpx
- ✓ Menjalankan Nuclei
- ✓ Membuat timeline
- ✓ Menghasilkan JSON Report
- ✓ Menghasilkan HTML Report
- ✓ Menghasilkan PDF Report
- ✓ Menghasilkan Risk Score
- ✓ Berjalan pada Windows dan Linux
- ✓ Read Only Operation